Detectando lo que las reglas y las líneas base no ven: UEBA basado en series de tiempo

Alejandro Higuera Castro

Departamento de Estadística, Facultad de Ciencias
Universidad Nacional de Colombia, Sede Bogotá, Colombia
ahiguerac@unal.edu.co

Resumen Los centros de operaciones de seguridad (SOC) buscan amenazas internas con reglas de umbral y líneas base estáticas que generan tantas falsas alarmas que desgastan y desensibilizan a los analistas. Este trabajo trata la actividad de cada usuario como una serie de tiempo con ciclo semanal y aplica la metodología Box-Jenkins a la analítica del comportamiento de usuarios (UEBA): cada noche, un modelo SARIMA pronostica cada uno de los nueve contadores de actividad de cada usuario, mide cuánto se aleja lo observado de lo normal para esa persona y entrega al SOC los casos más anómalos del día. En CERT r4.2 (1.000 usuarios, 500 días, 70 incidentes), con las mismas 10 alertas diarias que una regla global y una línea base estática, SARIMA encuentra 240 días maliciosos, frente a 163 de la estática (47 % más) y 36 de la regla global, y detecta 67 de los 70 incidentes (estática, 64; global, 17). Tiene potencial para reducir el trabajo de los equipos de seguridad y la fatiga de alertas: la línea base estática necesita 18 alertas diarias para encontrar lo que SARIMA encuentra con 10, y el analista revisa 14 alertas por cada día malicioso encontrado, en vez de 21.

Palabras clave: Amenaza interna · UEBA · Series de tiempo · SARIMA · Detección de anomalías · Fatiga de alertas

1. Introducción

Las firmas detectan amenazas conocidas, pero en gran medida no las desconocidas [5], como una persona que usa credenciales válidas con fines maliciosos (MITRE ATT&CK T1078). Los SOC usan reglas de umbral y perfiles [5], pero un umbral fijo trata igual un lunes que un domingo: dispara con actividad normal y calla ante anomalías que no lo alcanzan. Casi todas las alarmas son falsos positivos, revisarlas desgasta a los analistas [1] y así se pierden ataques [3].

La actividad de un usuario, como el tráfico de red [2], es una serie de tiempo con ciclo semanal, y su línea base debería modelarla. ¿Con las alertas que un SOC puede revisar, un modelo por usuario detecta más que una regla global y una línea base estática? El aporte son modelos Box-Jenkins interpretables, uno por usuario y contador, evaluados con igual carga de trabajo y con la proporción

real de casos (0,32 % de días maliciosos); no se comparan con redes profundas como BRITD [6] y BTITD [8].

2. Datos y método

Datos. CERT r4.2 [4] simula 1.000 usuarios durante 500 días y registra 70 incidentes: fuga de información a WikiLeaks fuera de horario (30), robo de datos antes de renunciar (30) y sabotaje con la cuenta del supervisor (10). Un usuario-día es malicioso si tiene un evento del incidente.

Cómo funciona. Cada noche: (1) se resumen los registros que ya centraliza el SIEM en nueve contadores por usuario y día (sesiones, USB, archivos, correo y web, también fuera de 07:00 a 19:00); (2) para cada usuario y contador, un modelo pronostica el valor esperado del día y su *límite del 99 %*, el valor que un día normal no debería superar más de 1 vez de cada 100; (3) el puntaje del usuario es su mayor aumento sobre el pronóstico de log(1 + conteo), en desviaciones estándar; (4) el SOC revisa los k usuarios con mayor puntaje.

Modelos. Se comparan la regla global (un umbral para todos), la línea base estática (media y desviación de cada usuario, recalculadas cada mes), la regla ingenua (hoy igual que hace una semana), ARIMA, SARIMA y SARIMAX (con la mediana del departamento). Según Box-Jenkins, de 5.700 series con actividad, el 94 % tiene ciclo semanal y en el 96 % ADF (sin el promedio de cada día) y KPSS son compatibles con estacionariedad; por AIC se eligió SARIMA$(0,0,0)(1,0,1)_7$. Sus coeficientes ($\Phi \approx 1$, $\Theta \approx -1$) lo vuelven un perfil por día de la semana que se actualiza lentamente; las series casi vacías (37 % de los ajustes) usan la media del usuario.

Evaluación. Se entrena hasta el 2010-06-09, antes de cualquier incidente, y se prueba hasta el 2011-05-16, reentrenando cada mes con 182 días, sin usar etiquetas [7], o, como control, una sola vez. Se mide cuánto se detecta con k alertas diarias y la precisión promedio (PR-AUC; al azar, 0,0032), con intervalos de confianza (IC) del 95 % por bootstrap de usuarios.

3. Resultados

Con igual carga de trabajo, los modelos de series de tiempo superan a las reglas en toda la Tabla 1; con 10 alertas diarias, SARIMA encuentra 240 días maliciosos, frente a 163 de la estática (+47 %; IC del 95 % de la diferencia: 43 a 117) y 36 de la regla global. SARIMA supera a la estática con 1 a 30 alertas diarias, aun sin reentrenar, y en PR-AUC (+0,0062; IC: 0,0025 a 0,0108).

Sin tope diario, la regla global dispara 108 alertas al día y SARIMA, 18,5 (falsas: 98 y 95 de cada 100). La estática necesita 18 alertas diarias para alcanzar los 240 días de SARIMA con 10. El perfil semanal (media y desviación de cada usuario por día de la semana), un control temporal más simple, también supera a la estática con cualquier número de alertas (con 10, 47 días más; IC: 24 a 74); frente a SARIMA encuentra menos con 3 a 17 alertas diarias y más con 18 o más. La ventaja se concentra en el robo de datos antes de renunciar (861 de

Tabla 1. Detecciones con igual número de alertas diarias. Abajo, enfoques temporales.

	Días maliciosos (de 986)				Con 10 alertas diarias		
Detector	3/día	5/día	10/día	20/día	Incidentes	Aciertos/100	PR-AUC
Regla global	16	19	36	42	17/70	1,1	0,0125
Línea base estática	52	82	163	258	64/70	4,8	0,0270
Regla ingenua	32	53	93	157	46/70	2,7	0,0118
Perfil semanal (control)	75	128	210	**322**	**67/70**	6,2	**0,0361**
ARIMA	**85**	126	220	293	**67/70**	6,5	0,0346
SARIMA	81	**146**	**240**	300	**67/70**	**7,0**	0,0331
SARIMAX + pares	83	131	234	305	65/70	6,9	0,0330

los 986 días maliciosos): SARIMA encuentra 167 y la estática, 86; en los otros dos escenarios, 73 y 77. El límite es conservador: los días normales lo superaron del 0,2 % al 0,8 % de las veces (nominal, 1 %). En PR-AUC no hubo evidencia de diferencias entre los tres modelos, pero sin reentrenar SARIMA conserva su PR-AUC (0,0339) y ARIMA cae a 0,0204, bajo la estática (0,0277). Ljung-Box no rechaza residuos sin autocorrelación en el 95 % de los ajustes iniciales de SARIMA y el 82 % de los mensuales (nominal, 95 %); en ARIMA, el 9 %.

4. Conclusiones

Un modelo de series de tiempo aprende el ritmo de cada usuario; un umbral fijo, no. Con 10 alertas diarias, los tres modelos detectan entre 35 % y 47 % más días maliciosos que la estática, y SARIMA, 6,7 veces los de la regla global; el analista revisa 14,2 alertas por día malicioso encontrado en vez de 20,9, lo que ayuda a reducir la fatiga de alertas. El ritmo semanal hay que estimarlo: copiar la semana anterior encuentra 93 días. No ve costumbres del usuario ni acciones sin cambio de volumen (para eso están la regla global, el EDR y las firmas), y se probó en datos sintéticos: una alerta no confirma un ataque.

Referencias

1. Alahmadi, B.A., Axon, L., Martinovic, I.: 99 % false positives: A qualitative study of SOC analysts' perspectives on security alarms. In: USENIX Security (2022)
2. Brutlag, J.D.: Aberrant behavior detection in time series for network monitoring. In: 14th Systems Administration Conference (LISA 2000). pp. 139–146. USENIX (2000)
3. Hassan, W.U., et al.: NoDoze: Combatting threat alert fatigue with automated provenance triage. In: NDSS Symposium (2019)
4. Lindauer, B.: Insider threat test dataset (2020). `https://doi.org/10.1184/R1/12841247`
5. Scarfone, K., Mell, P.: Guide to intrusion detection and prevention systems (IDPS). Tech. Rep. SP 800-94, NIST (2007)
6. Song, S., Gao, N., Zhang, Y., Ma, C.: BRITD: behavior rhythm insider threat detection with time awareness and user adaptation. Cybersecurity **7**, 2 (2024)
7. Tashman, L.J.: Out-of-sample tests of forecasting accuracy: an analysis and review. International Journal of Forecasting **16**(4), 437–450 (2000)
8. Zhang, C., et al.: BTITD: an insider threat detection method based on behavior-timestamp dual-stream network. Cybersecurity **9**, 179 (2026)